

Informe SQUARE.

El marco SQUARE nació para domar requisitos de seguridad en proyectos concretos; tú quieres usarlo como brújula estadística para un país entero. Ambicioso, luego razonable.

1. Qué es SQUARE hoy (y qué no)

SQUARE (Security Quality Requirements Engineering) sigue siendo, en esencia, un proceso en nueve pasos para **elicitación y priorización de requisitos de seguridad** en sistemas concretos, desarrollado por el CERT del SEI de Carnegie Mellon. No se ha “reeditado” como estándar nuevo tras 2005, pero se cita aún en trabajos recientes como uno de los métodos canónicos de requisitos de seguridad.¹²³⁴⁵

Esos nueve pasos (acuerdo sobre objetivos, definición de términos, identificación de activos, selección de técnicas, perfilado del riesgo, elicitación, categorización, priorización, y revisión/inspección) producen, como artefacto final, un documento de requisitos de seguridad trazable y verificable. SQUARE nunca definió un “cuadro de mando nacional”; lo que ofrece es una gramática estable para convertir amenazas y objetivos de negocio en requisitos cuantificables y medibles a nivel de sistema.⁶⁷⁸⁹

Desde 2023-2025, la literatura de ingeniería de requisitos y calidad de software retoma SQUARE como referencia cuando discute procesos de requisitos de seguridad, pero orienta la innovación hacia modelos de calidad, métricas cuantitativas y marcos más amplios (p. ej. SQuaRE de ISO/IEC 25010/2502x para calidad de software). La tensión, para nuestro propósito, es clara: SQUARE da forma y trazabilidad; SQuaRE y la ingeniería de calidad proveen estructuras para definir métricas y umbrales.¹⁰¹¹

1 <https://www.sei.cmu.edu/library/security-quality-requirements-engineering-square/>

2 <https://arxiv.org/html/2402.08436v3>

3 <https://www.sciencedirect.com/science/article/pii/S2452414X23000389>

4 https://www.sei.cmu.edu/documents/751/2005_005_001_14594.pdf

5 <https://arxiv.org/html/2402.08436v3>

6 <https://www.sciencedirect.com/science/article/pii/S2452414X23000389>

7 https://www.ida.liu.se/~TDDC90/literature/papers/mead_sess05.pdf

8 <https://www.sei.cmu.edu/library/security-quality-requirements-engineering-technical-report/>

9 https://www.sei.cmu.edu/documents/751/2005_005_001_14594.pdf

10 https://www.ida.liu.se/~TDDC90/literature/papers/mead_sess05.pdf

11 <https://www.springerprofessional.de/software-quality-as-a-foundation-for-security/26968238>

2. Indicadores internos en SQUARE: micro-métrica con vocación macro

Aunque los textos fundacionales de SQUARE no presentan un catálogo “oficial” de KPI, sí sugieren explícitamente que los requisitos deben ser verificables y, por tanto, medibles. En las aplicaciones de caso, la priorización se apoya en etiquetas como “esencial/condicional/opcional” en función del riesgo, lo que introduce de facto una taxonomía de criticidad y un espacio para métricas.¹²¹³¹⁴

De SQUARE se pueden extraer tres familias de indicadores (a nivel de proyecto o sistema) que son trasladables a nivel sectorial o nacional:

1. Indicadores de cobertura de requisitos:

Porcentaje de funciones críticas de negocio con requisitos de seguridad explícitos documentados (numerador: funciones con requisitos; denominador: funciones críticas identificadas en el paso de identificación de activos).²⁶

Porcentaje de amenazas de alto impacto identificadas para las que existe al menos un requisito mitigador verificado en el documento final.⁶²

2. Indicadores de calidad de los requisitos:

Porcentaje de requisitos que cumplen criterios de buena ingeniería (no ambiguos, verificables, trazables a un objetivo y a un riesgo concreto).²

Porcentaje de requisitos que pasan la inspección final sin observaciones sustantivas en la fase de revisión.²

3. Indicadores de alineamiento riesgo-requisito:

Distribución de requisitos en las categorías esencial/condicional/opcional frente a la distribución de amenazas por nivel de riesgo, detectando desajustes (por ejemplo, muchas amenazas críticas con pocos requisitos esenciales asociados).⁶

Número de activos críticos sin requisitos asociados frente al total de activos críticos identificados.⁶²

- Porcentaje de funciones críticas de negocio con requisitos de seguridad explícitos documentados (numerador: funciones con requisitos; denominador: funciones críticas identificadas en el paso de identificación de activos).²⁶
- Porcentaje de amenazas de alto impacto identificadas para las que existe al menos un requisito mitigador verificado en el documento final.⁶²

¹² <https://dl.acm.org/doi/pdf/10.1145/1082983.1083214>

¹³ <https://dl.acm.org/doi/pdf/10.1145/1082983.1083214>

¹⁴ <https://arxiv.org/html/2402.08436v3>

- Porcentaje de requisitos que cumplen criterios de buena ingeniería (no ambiguos, verificables, trazables a un objetivo y a un riesgo concreto).²
- Porcentaje de requisitos que pasan la inspección final sin observaciones sustantivas en la fase de revisión.²
- Distribución de requisitos en las categorías esencial/condicional/opcional frente a la distribución de amenazas por nivel de riesgo, detectando desajustes (por ejemplo, muchas amenazas críticas con pocos requisitos esenciales asociados).⁶
- Número de activos críticos sin requisitos asociados frente al total de activos críticos identificados.⁶²

Estos indicadores nacen en el nivel micro (proyecto), pero su potencia política aparece cuando se estandarizan y se agregan: un regulador puede pedir, por ejemplo, que todos los operadores de sectores NIS2 reporten anualmente la “densidad de requisitos esenciales por activo crítico” como medida indirecta de madurez de ingeniería de seguridad.

3. Tendencias recientes (desde 2025): SQUARE dentro del ecosistema de métricas

Aunque no hay una “versión 2025” del método, se observan tres tendencias en la literatura reciente y en foros como SWQD 2024 o REFSQ 2024-2025.¹⁵¹⁶¹⁷

¹⁵ <https://www.springerprofessional.de/software-quality-as-a-foundation-for-security/26968238>

¹⁶ <https://www.sciencedirect.com/science/article/pii/S0164121221002661>

¹⁷ <https://dblp.org/db/conf/refsq/refsq2024.html>

4. Convergencia con modelos de calidad:

Se impulsa el uso de modelos de calidad (como ISO/IEC 25010 SQuaRE) para fundamentar métricas de seguridad, tratando la seguridad como atributo de calidad con características y subcaracterísticas medibles.⁹⁸

SQUARE se cita como mecanismo sistemático de recogida y priorización de requisitos que luego se mapean a esos modelos para obtener indicadores comparables entre sistemas y organizaciones.³⁴⁸

5. Orientación a métricas cuantitativas de “confianza”:

La colección de “Cybersecurity Quality Metrics” del SEI ya planteaba la idea de usar modelos de calidad para seguir y predecir defectos de seguridad, postulando umbrales a partir de los cuales se considera que la seguridad operativa es incierta.¹²

Trabajos recientes sobre “software quality as a foundation for security” refuerzan este enfoque: más que contar controles aislados, interesa medir niveles de calidad del proceso y del producto, y usar esos niveles como proxies de riesgo residual.¹²⁸

6. Sistematización de marcos nacionales:

ENISA ha desarrollado un marco para evaluar la madurez de las Estrategias Nacionales de Ciberseguridad (NCSS), organizado en clusters (gobernanza, capacidades, marco legal, cooperación) con indicadores asociados.¹³¹⁴

En 2025 publica además guías para la implementación de NIS2, estructuradas en bloques de requisitos (política de seguridad, gestión de incidentes, continuidad, etc.), que invitan a definir métricas de cumplimiento y eficacia por bloque.¹⁵

- Se impulsa el uso de modelos de calidad (como ISO/IEC 25010 SQuaRE) para fundamentar métricas de seguridad, tratando la seguridad como atributo de calidad con características y subcaracterísticas medibles.⁹⁸
- SQUARE se cita como mecanismo sistemático de recogida y priorización de requisitos que luego se mapean a esos modelos para obtener indicadores comparables entre sistemas y organizaciones.³⁴⁸
- La colección de “Cybersecurity Quality Metrics” del SEI ya planteaba la idea de usar modelos de calidad para seguir y predecir defectos de seguridad, postulando umbrales a partir de los cuales se considera que la seguridad operativa es incierta.¹²
- Trabajos recientes sobre “software quality as a foundation for security” refuerzan este enfoque: más que contar controles aislados, interesa medir niveles de calidad del proceso y del producto, y usar esos niveles como proxies de riesgo residual.¹²⁸

- ENISA ha desarrollado un marco para evaluar la madurez de las Estrategias Nacionales de Ciberseguridad (NCSS), organizado en clusters (gobernanza, capacidades, marco legal, cooperación) con indicadores asociados.¹³¹⁴
- En 2025 publica además guías para la implementación de NIS2, estructuradas en bloques de requisitos (política de seguridad, gestión de incidentes, continuidad, etc.), que invitan a definir métricas de cumplimiento y eficacia por bloque.¹⁵

La consecuencia pragmática es que SQUARE, aunque no se haya “actualizado”, se integra cómodamente como método de ingeniería dentro de un ecosistema de métricas nacionales dictado por NIS2, ENISA e iniciativas de métricas de calidad del SEI.¹⁸¹⁹²⁰²¹

4. Aplicación a España: del documento de requisitos al cuadro de mando país

En España, el contexto normativo y estadístico está marcado por la transposición de NIS2, la estrategia nacional de ciberseguridad y el rol operativo de INCIBE y el CCN-CERT. INCIBE, por ejemplo, reporta anualmente el número y tipología de incidentes gestionados (122 223 en 2025, con desglose por malware, fraude online, phishing, ransomware, accesos no autorizados, etc.) y el número de sistemas vulnerables notificados (237 028 en 2025).²²²³²⁴²⁵²⁶

Estos son indicadores de resultado (incidentes, vulnerabilidades) valiosos, pero en su versión actual apenas dicen nada de la calidad de los requisitos de seguridad que debían haber prevenido esos incidentes. Aquí es donde SQUARE permite “inyectar ingeniería” en la estadística nacional. Una posible arquitectura de indicadores SQUARE-compatibles, a nivel territorial, podría articularse en tres niveles:²⁷²⁸

18 https://www.sei.cmu.edu/documents/751/2005_005_001_14594.pdf

19 <https://2023.refsq.org/series/refsq>

20 <https://insights.sei.cmu.edu/library/cybersecurity-engineering-research-cybersecurity-quality-metrics-collection/>

21 <https://dl.acm.org/doi/pdf/10.1145/1082983.1083214>

22 <https://www.enisa.europa.eu/topics/state-of-cybersecurity-in-the-eu/national-cybersecurity-strategies>

23 <https://www.enisa.europa.eu/topics/national-cyber-security-strategies/ncss-map/national-cyber-security-strategies-interactive-map?selected=Spain>

24 <https://www.esmartcity.es/2025/06/30/enisa-publica-guia-ayudar-implementacion-directiva-nis2-ciberseguridad>

25 <https://www.incibe.es/en/ed2026/talento-hacker/publications/european-cybersecurity-skills/case>

26 https://www.sei.cmu.edu/documents/751/2005_005_001_14594.pdf

27 <https://www.enisa.europa.eu/topics/state-of-cybersecurity-in-the-eu/national-cybersecurity-strategies>

28 <https://www.esmartcity.es/2025/06/30/enisa-publica-guia-ayudar-implementacion-directiva-nis2-ciberseguridad>

7. Nivel organización (aplicación directa de SQUARE):

Requisito de que sectores esenciales e importantes (NIS2) apliquen algún proceso SQUARE-like para sistemas críticos, generando informes estandarizados.

Cada informe incorpora métricas de cobertura, calidad y alineamiento riesgo-requisito como las descritas antes.²⁶

8. Nivel sectorial:

Agregación de indicadores: porcentaje medio de activos críticos con requisitos esenciales por subsector, distribución de requisitos por tipo de amenaza (confidencialidad, integridad, disponibilidad, etc.), porcentaje de requisitos revisados sin observaciones.

Inclusión de correlaciones con indicadores operativos: por ejemplo, número de incidentes de un tipo por unidad de “densidad de requisitos” que teóricamente debían mitigarlos.

9. Nivel nacional:

Construcción de un índice compuesto de madurez de requisitos de seguridad, ponderando cobertura, calidad y alineamiento en organizaciones clave, y comparándolo año a año.

Integración con los marcos de evaluación de ENISA (NCSS, NIS2) para mapear indicadores SQUARE-derivados en los clusters de gobernanza, capacidades y estándares.¹⁴¹⁵¹³

- Requisito de que sectores esenciales e importantes (NIS2) apliquen algún proceso SQUARE-like para sistemas críticos, generando informes estandarizados.
- Cada informe incorpora métricas de cobertura, calidad y alineamiento riesgo-requisito como las descritas antes.²⁶
- Agregación de indicadores: porcentaje medio de activos críticos con requisitos esenciales por subsector, distribución de requisitos por tipo de amenaza (confidencialidad, integridad, disponibilidad, etc.), porcentaje de requisitos revisados sin observaciones.
- Inclusión de correlaciones con indicadores operativos: por ejemplo, número de incidentes de un tipo por unidad de “densidad de requisitos” que teóricamente debían mitigarlos.
- Construcción de un índice compuesto de madurez de requisitos de seguridad, ponderando cobertura, calidad y alineamiento en organizaciones clave, y comparándolo año a año.
- Integración con los marcos de evaluación de ENISA (NCSS, NIS2) para mapear indicadores SQUARE-derivados en los clusters de gobernanza, capacidades y estándares.¹⁴¹⁵¹³

España dispone de datos de incidentes y vulnerabilidades; lo que falta es precisamente esa capa intermedia de ingeniería de requisitos que conecte las cifras con decisiones de diseño. Un consorcio

nacional podría, por ejemplo, exigir que todo expediente de financiación pública de infraestructuras críticas presentase un “anexo SQUARE” con métricas mínimas reportables.²⁹³⁰

5. Comparativa internacional: cómo podría medirse España frente al mundo

Si se quisiera posicionar a España en una comparativa mundial basada en indicadores SQUARE-inspirados, habría que reconocer primero que casi ningún país ha adoptado SQUARE como nombre de bandera a nivel nacional. Los marcos más visibles son:

- En la UE: ENISA y NIS2, que establecen obligaciones de gestión de riesgos, reporting de incidentes y medidas técnicas/organizativas, pero no fijan un método único de requisitos.¹⁵¹⁴¹³
- En EEUU: guías de gestión de riesgo (por ejemplo, en sectores como energía) que mencionan la necesidad de métricas para medir la conformidad con arquitecturas de ciberseguridad e incluso referencian SQUARE en apéndices como método de apoyo.¹⁹
- A nivel académico/industrial: colecciones como “Cybersecurity Quality Metrics” del SEI, que exploran modelos cuantitativos de calidad para seguridad, sin atarse a un país concreto.¹²

Esto dibuja una situación paradójica: existen piezas dispersas (procesos de requisitos tipo SQUARE, modelos de calidad tipo SquaRE, marcos nacionales tipo ENISA/NCSS, indicadores de incidentes tipo INCIBE), pero pocos países las han ensamblado de forma explícita en un sistema coherente de métricas de requisitos de seguridad.

Bajo esa luz, España podría situarse en un pelotón medio-alto: dispone de un CERT nacional activo, informes estadísticos detallados, participación en foros europeos, y una tradición no menor en ingeniería de requisitos (basta ver la elección de Barcelona como sede de REFSQ 2025). Lo que falta, y aquí SQUARE juega el papel de brújula, es una política explícita de “ingeniería de requisitos como política pública de ciberseguridad”, con KPI normalizados que sobrevivan al cambio de proveedor.³¹³²³³

Un posible planteamiento de comparación podría contemplar:

- Densidad de informes de requisitos de seguridad por sistema crítico financiado con fondos públicos.
- Porcentaje de estrategias nacionales que exigen procesos formales de ingeniería de requisitos de seguridad (SQUARE u otros).
- Existencia de metodologías oficiales de ejercicio de ciberseguridad donde se simula no solo la respuesta a incidentes, sino el fallo de requisitos de seguridad (ENISA ya ha publicado en 2026 una metodología para ejercicios, que podría ampliarse en esa dirección).²⁰

²⁹ <https://digitalperito.es/blog/incibe-balance-2025-122000-ciberincidentes-espana/>

³⁰ <https://www.enisa.europa.eu/topics/state-of-cybersecurity-in-the-eu/national-cybersecurity-strategies>

³¹ https://www.ida.liu.se/~TDDC90/literature/papers/mead_sess05.pdf

³² <https://www.enisa.europa.eu/topics/state-of-cybersecurity-in-the-eu/national-cybersecurity-strategies>

³³ <https://www.incibe.es/incibe/sala-de-prensa/incibe-detecto-mas-de-122000-incidentes-de-ciberseguridad-en-2025>

En términos literarios: casi todos cuentan incendios; muy pocos auditan la calidad de los planos de los edificios.

6. Propuesta de indicadores SQUARE-compatibles para España (2025+)

Una propuesta propositiva (y algo irónica) para un “Informe SQUARE España” podría contemplar:

- En cada sistema crítico de operadores esenciales:
Porcentaje de amenazas de alto riesgo con requisito esencial asociado, medido tras la fase de priorización SQUARE.⁶²
Porcentaje de requisitos que, en la inspección final, se consideran verificables mediante pruebas o evidencias objetivas (no fe ni declaraciones juradas).²
Número medio de iteraciones de revisión hasta lograr un documento de requisitos sin observaciones críticas, como proxy de madurez del proceso.²
- A nivel sectorial:
Ratio entre incidentes reportados (por tipo) e intensidad de requisitos relevantes (por ejemplo, incidentes de ransomware por número de requisitos esenciales de backup, segmentación y restauración definidos).¹⁷¹⁸¹²
Evolución anual de la cobertura de requisitos sobre activos recién introducidos (nuevos sistemas conectados, nuevas integraciones OT-IT).
- A nivel nacional:
Índice de madurez de requisitos de seguridad, que agregue cobertura, calidad y alineamiento, con metas alineadas con el marco de evaluación de ENISA.¹⁴¹³¹⁵
Indicadores de capacidades: número de profesionales formados en métodos de requisitos de seguridad (SQUARE, Tropos, etc.), enlazado con iniciativas de talento en ciberseguridad ya recogidas por ENISA e INCIBE.¹⁶
- Porcentaje de amenazas de alto riesgo con requisito esencial asociado, medido tras la fase de priorización SQUARE.⁶²
- Porcentaje de requisitos que, en la inspección final, se consideran verificables mediante pruebas o evidencias objetivas (no fe ni declaraciones juradas).²
- Número medio de iteraciones de revisión hasta lograr un documento de requisitos sin observaciones críticas, como proxy de madurez del proceso.²
- Ratio entre incidentes reportados (por tipo) e intensidad de requisitos relevantes (por ejemplo, incidentes de ransomware por número de requisitos esenciales de backup, segmentación y restauración definidos).¹⁷¹⁸¹²
- Evolución anual de la cobertura de requisitos sobre activos recién introducidos (nuevos sistemas conectados, nuevas integraciones OT-IT).

- Índice de madurez de requisitos de seguridad, que agregue cobertura, calidad y alineamiento, con metas alineadas con el marco de evaluación de ENISA.141315
- Indicadores de capacidades: número de profesionales formados en métodos de requisitos de seguridad (SQUARE, Tropos, etc.), enlazado con iniciativas de talento en ciberseguridad ya recogidas por ENISA e INCIBE.16

Todo ello debería acompañarse de una narrativa política clara: el objetivo no es llenar repositorios de PDFs de requisitos, sino reducir la entropía entre lo que la política declara, lo que la ingeniería diseña y lo que las estadísticas de incidentes revelan.

212223242526272829303132333435363738394041